



Arab Academy for Science, Technology and Maritime Transport

College of Computing and Information Technology

Cybersecurity Department

Cybersecurity Risk Assessment of a Social Media Platform

Presented By:

Amer Ashoush 221006722

Ali Aboela 221002493

Omar Maher 221006560

Supervised By:

Dr. Moustafa Shokry

May – 2026

Contents

1	Introduction	2
2	Selected Risk Management Framework	2
3	System Description	2
3.1	System Purpose	2
3.2	Users and Stakeholders	3
3.3	Data Types	3
3.4	Business Processes	3
4	Asset Identification	3
5	Threat Identification	4
6	Vulnerability Identification	5
7	Risk Identification	5
8	Risk Analysis	6
8.1	Likelihood Scale	6
8.2	Impact Scale	7
9	Risk Evaluation	7
10	Risk Treatment	8
11	Control Implementation	9
12	Asset-Control Mapping	10
13	Conclusion	11

1 Introduction

This report presents a structured cybersecurity risk management analysis for a social media platform. The objective is to identify potential risks affecting the confidentiality, integrity, and availability of the system, and to propose appropriate treatment strategies. The analysis follows a formal risk management approach based on an established standard, ensuring that all steps are clearly defined and justified. The selected system represents a realistic environment where multiple users interact with sensitive data, making it suitable for risk assessment.

2 Selected Risk Management Framework

For this project, the NIST SP 800-30 standard, “Guide for Conducting Risk Assessments,” was selected as the basis for the risk management process.

This standard was chosen because it provides a structured and detailed approach to identifying, analyzing, and evaluating cybersecurity risks. Unlike more general frameworks, NIST SP 800-30 focuses specifically on risk assessment methodology, making it suitable for analyzing technical systems such as a social media platform.

Additionally, the framework allows clear mapping between assets, threats, vulnerabilities, and risk levels, which supports practical implementation using risk management tools such as SimpleRisk. Its structured phases also ensure that each step of the analysis is justified and can be explained during evaluation.

3 System Description

This section highlights the Purpose of the System proposed, Users and Stakeholders, Types of Data, and Business Process

3.1 System Purpose

The selected system is a social media platform that allows users to create accounts, share content, and interact with other users. The platform supports functionalities such as posting text, images, and videos, as well as liking, commenting, and messaging.

The system is designed to handle a large number of users and continuously process user-generated content. Due to the nature of the platform, it stores and processes sensitive user information, making it a relevant case for cybersecurity risk analysis.

3.2 Users and Stakeholders

The system involves multiple types of users and stakeholders, each with different roles and responsibilities.

End users are the primary users of the platform, responsible for creating content and interacting with others. Administrators manage the platform, enforce policies, and handle moderation tasks. Developers are responsible for maintaining and updating the system. Additionally, third-party stakeholders such as advertisers and analytics providers may interact with the system to deliver services.

Each of these stakeholders has a different level of access to system resources, which introduces varying levels of risk.

3.3 Data Types

The system processes multiple types of data, including personally identifiable information (PII) such as names, email addresses, and phone numbers. It also handles authentication data such as passwords and session tokens.

In addition, the platform stores user-generated content such as posts, images, and videos. Metadata, including timestamps and location data, is also collected. System logs are generated to track user activity and system events.

The presence of sensitive and high-value data increases the impact of potential security incidents.

3.4 Business Processes

The platform supports several core business processes that are essential for its operation. These include user registration and authentication, content creation and sharing, user interaction through comments and messages, and content moderation.

Other processes include data storage and retrieval, analytics for user engagement, and advertisement delivery. The continuous availability and integrity of these processes are critical to maintaining user trust and system functionality.

4 Asset Identification

The first step in the risk assessment process is identifying the critical assets within the system. These assets represent components that store, process, or transmit valuable information and are essential to system operation.

Asset ID	Asset Name	Description	Owner
A1	User Database	Stores user credentials and PII	DBA
A2	Authentication Server	Handles login and sessions	IT Admin
A3	Web Application	Frontend/backend logic	Dev Team
A4	Media Storage	Stores images/videos	Cloud Admin
A5	Messaging System	Private communication	Backend Team
A6	Logging System	Stores logs	Security Team
A7	API Services	System communication	DevOps Team

Table 1: Asset Identification

As shown in Figure 1, the asset list is implemented in SimpleRisk.

Actions	Asset Name	IP Address	Asset Valuation	Site/Location	Team	Asset Details	Tags
	Asset Name	IP Address	Asset Valuation	Site/Location	Team	Asset Details	Tags
 	API Services	10.0.2.50	\$700,001 to \$800,000	All Sites	Web Systems	Provides endpoints for communication between system components and external services.	API Integration
 	Authentication Server	10.0.1.20	\$700,001 to \$800,000	All Sites	Information Security	Handles user authentication, session management, and access control. It verifies user identity and grants access to system resources.	Access Control Authentication
 	Logging System	10.0.4.10	\$300,001 to \$400,000	All Sites	IT Systems Management	Collects logs related to system activity, user behavior, and security events for monitoring and analysis.	Logs Monitoring
 	Media Storage	10.0.3.15	\$500,001 to \$600,000	All Sites	Data Center & Storage	Stores user-uploaded media such as images and videos. Responsible for maintaining data availability and confidentiality.	Media Storage
 	Messaging System	10.0.2.30	\$400,001 to \$500,000	All Sites	Web Systems	Handles private communication between users and processes sensitive message data.	Messaging Privacy
 	User Database	10.0.1.10	\$900,001 to \$1,000,000	All Sites	Database	Stores user credentials and personally identifiable information (PII), including emails and passwords. This asset is critical for authentication and user management, and its compromise would severely impact confidentiality.	Critical Database PII
 	Web Application	10.0.1.30	\$700,001 to \$800,000	All Sites	Web Systems	Processes user input and implements business logic. It serves as the main interface between users and the platform.	Application Web

Figure 1: Asset List in SimpleRisk

5 Threat Identification

Threats represent potential events or actors that may exploit system vulnerabilities and impact assets.

Threat ID	Threat
T1	Unauthorized access
T2	Data breach
T3	Phishing
T4	Malware injection
T5	DDoS
T6	Insider misuse
T7	API abuse

Table 2: Threat Identification

6 Vulnerability Identification

Vulnerabilities are weaknesses in the system that can be exploited by threats to compromise assets. These weaknesses may exist due to design flaws, misconfigurations, or lack of security controls.

Vulnerability ID	Description
V1	Weak password policies
V2	Lack of MFA
V3	Unencrypted data storage
V4	Poor input validation
V5	No rate limiting
V6	Misconfigured access controls
V7	Lack of monitoring/logging

Table 3: Vulnerability Identification

7 Risk Identification

Risks are identified by analyzing how specific threats can exploit vulnerabilities in system assets, leading to potential impact or loss.

Risk	Asset	Threat	Vulnerability	Impact
R1	User Database	Data breach	Weak encryption	Data exposure
R2	Authentication Server	Unauthorized	No MFA	Account takeover
R3	Web Application	Malware	Input validation	Compromise
R4	Media Storage	Data breach	Misconfig	Exposure
R5	Messaging System	Insider	No monitoring	Privacy issue
R6	API	Abuse	No rate limit	Disruption
R7	Web Application	DDoS	No rate limit	Downtime

Table 4: Risk Identification

As shown in Figure 2, the risk register process is implemented in SimpleRisk.

ID	Status	Subject	Inherent Risk (Current)	Submission Date	Mitigation Planned	Management Review
1002	Mitigation Planned	Data Breach in User Database	8 	04/27/2026 4:50 AM CDT	Yes 	No 
1003	Mitigation Planned	Unauthorized Access to Authentication Server	6.4 	04/27/2026 5:23 AM CDT	Yes 	No 
1008	Mitigation Planned	DDoS Attack on Web Application	6.4 	04/27/2026 2:37 PM CDT	Yes 	No 
1004	Mitigation Planned	Malware Injection in Web Application	4.8 	04/27/2026 2:17 PM CDT	Yes 	No 
1005	Mitigation Planned	API Abuse due to Lack of Rate Limiting	4.8 	04/27/2026 2:22 PM CDT	Yes 	No 
1006	Mitigation Planned	Media Storage Data Exposure	4.8 	04/27/2026 2:24 PM CDT	Yes 	No 
1007	Mitigation Planned	Insider Misuse due to Lack of Monitoring	3.6 	04/27/2026 2:33 PM CDT	Yes 	No 

Figure 2: Risk Register in SimpleRisk

8 Risk Analysis

Risk analysis is performed to determine the likelihood and impact of each identified risk. A qualitative approach is used, where risks are evaluated based on predefined scales for likelihood and impact.

8.1 Likelihood Scale

- 1: Rare
- 2: Unlikely

- 3: Possible
- 4: Likely
- 5: Almost Certain

8.2 Impact Scale

- 1: Negligible
- 2: Minor
- 3: Moderate
- 4: Major
- 5: Catastrophic

As shown in Figure 3, the risk scoring process is implemented in SimpleRisk.

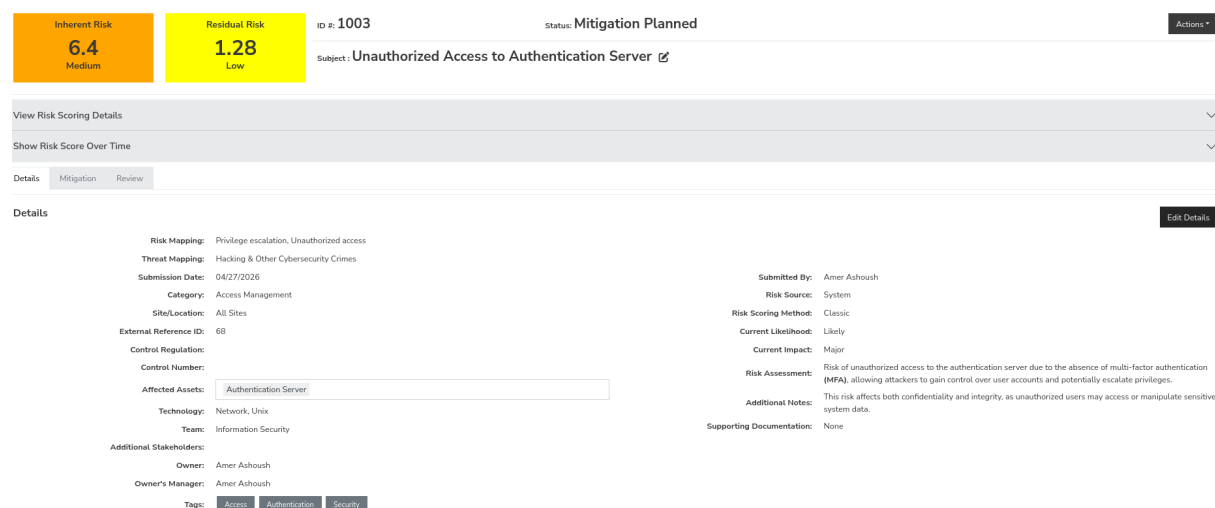


Figure 3: Risk Scoring example

9 Risk Evaluation

Risk evaluation involves comparing the analyzed risks against predefined acceptance criteria to determine which risks require treatment. High and critical risks are considered unacceptable and must be treated, while low risks may be accepted based on their limited impact.

Risk	Level	Decision
R1	Critical	Not Acceptable
R2	Critical	Not Acceptable
R3	High	Not Acceptable
R4	High	Not Acceptable
R5	High	Not Acceptable
R6	Medium	Conditionally Acceptable
R7	Critical	Not Acceptable

Table 5: Risk Evaluation

10 Risk Treatment

Risk treatment involves selecting appropriate actions to manage identified risks. Based on the evaluation, risks can be mitigated, accepted, transferred, or avoided.

Risk	Treatment	Control
R1	Mitigate	Encryption + Access Control
R2	Mitigate	MFA
R3	Mitigate	Input Validation
R4	Mitigate	Rate Limiting
R5	Mitigate	Secure Config
R6	Accept	Monitoring
R7	Transfer	Cloud Protection

Table 6: Risk Treatment

Inherent Risk

6.4

Medium

Residual Risk

1.28

Low

ID #: 1003

Status: Mitigation Planned

Actions ▾

Subject : Unauthorized Access to Authentication Server [🔗](#)

View Risk Scoring Details ▾

Show Risk Score Over Time ▾

Details

Mitigation

Review

Mitigation Edit Mitigation

Mitigation Submission Date:

04/28/2026

Planned Mitigation Date:

04/28/2026

Planning Strategy:

Mitigate

Mitigation Effort:

Significant

Mitigation Cost:

\$300,001 to \$400,000

Mitigation Owner:

Amer Ashoush

Mitigation Team:

Information Security

Mitigation Percent:

80

Current Solution:

Authentication exists without MFA and lacks monitoring.

Security Requirements:

Strong authentication and identity verification mechanisms.

Security Recommendations:

Enable MFA, secure session tokens, implement authentication logging.

Supporting Documentation:

None

Accept Mitigation

Figure 4: Risk Mitigation Entry

11 Control Implementation

Based on the identified risks, a set of security controls was implemented to reduce the likelihood and impact of potential threats. These controls were mapped to the corresponding assets and risks to ensure effective mitigation.

Control Short Name :

C3-InputValidation

Control Long Name :

Input Validation Control

Control Number :

3

Control Owner :

Control Phase :

Technical

Control Priority :

P1

Control Family :

PR.IP- 1

Current Control Maturity :

Managed

Mitigation Percent :

65

Desired Control Maturity :

Optimizing

Control Type :

Project

Control Class :

Technical

Control Status :

Pass

Description :

Validates user input to prevent injection attacks.

Supplemental Guidance :

Mapped Control Frameworks :

Framework	Control

Mapped Assets :

Current Maturity	Asset
Managed	Web Application

Figure 5: C3-Input Validation

Control Short Name :

C13-WAF

Control Long Name :

Web Application Firewall

Control Number :

13

Control Owner :

Control Priority :

P1

Current Control Maturity :

Performed

Desired Control Maturity :

Managed

Control Class :

Technical

Description :

Filters malicious web traffic and blocks attacks.

Control Phase :

Technical

Control Family :

PR,PT-1

Mitigation Percent :

60

Control Type :

Enterprise

Control Status :

Fail

Supplemental Guidance :

Mapped Control Frameworks :

Framework	Control
-----------	---------

Mapped Assets :

Current Maturity	Asset
Performed	Web Application

Figure 6: C13-WAF

12 Asset-Control Mapping

Each asset was associated with specific controls to ensure comprehensive protection against relevant risks. This mapping ensures that all system components are secured appropriately.

Edit Asset

Asset Name*

User Database

IP Address

10.0.1.10

Asset Valuation*

\$900,001 to \$1,000,000

Site/Location

All Sites

Team

Database

Asset Details

↶

↷

B

I

U

Paragraph

↶

↷

↶

↷

Stores user credentials and personally identifiable information (PII), including emails and passwords. This asset is critical for authentication and user management, and its compromise would severely impact confidentiality.

Mapped Controls

Current Maturity

Control

Actions

Managed

CB-RBAC

Performed

C1-Encryption

Not Performe

C9-DBMonitoring

Tags

Critical

Database

PII

Associated Risks

[1002] Data Breach in User Database

Cancel

Update

Figure 7: User Database Mapping

Edit Asset

Asset Name*

Web Application

IP Address

10.0.1.30

Asset Valuation*

\$700,001 to \$900,000

Site/Location

All Sites

Team

Web Systems

Asset Details

↶

↷

B

I

U

Paragraph

↶

↷

↶

↷

Processes user input and implements business logic. It serves as the main interface between users and the platform.

Mapped Controls

Current Maturity

Control

Actions

Not Performe

C4-RateLimit

Performed

C7-DDoS, C13-WAF

Managed

C3-InputValidation, C12-SecureCoding

Tags

Application

Web

Associated Risks

[1005] API Abuse due to Lack of Rate Limiting, [1008] DDoS Attack on Web Ap...

Cancel

Update

Figure 8: Web Application Mapping

13 Conclusion

The risk assessment identified several critical and high risks affecting the system, particularly related to data breaches, unauthorized access, and availability attacks. Appropriate controls and mitigation strategies were proposed to reduce these risks. While some risks were mitigated, others were accepted or transferred based on their impact and cost considerations. Overall, the assessment demonstrates the importance of structured risk management in securing modern applications.